GoreeCloud Search — Development Ingress Security and Public Release Hold

Document type: Engineering security/release hold | **Owner:** GoreeCloud | **Status:** Active Development, not release-qualified | **Revision:** 0.2 | **Verified:** October 24, 2026 (source guard and read-only network checks) | **Canonical source:** docs/goreecloud/SEARCH-DEVELOPMENT-INGRESS-RELEASE-HOLD.md

Scope: private Search Development source admission and independently verified public-host configuration gap; not a live-service or public-release certificate. **Authority:** GoreeCloud's current operating instructions, current repository configuration, and governed release lifecycle.

Two distinct hostnames

Host	Intended visibility	This gate's treatment
search-dev.goreecloud.com	Private, NetBird-only Development	Requires an exact 100.64.0.0/10 client matcher, its sole approved reverse-proxy upstream inside the matching handler, and an explicit 403 for everyone else.
search.goreecloud.com	Future public GoreeCloud Search	Requires separate public-product security, reliability, provider-rights and release acceptance. This Development check neither provisions nor qualifies it. It refuses a public Caddy block that forwards to the private Development gateway.

Offline admission guard

scripts/search_development_ingress_guard.py is deliberately read-only. It inspects an explicitly supplied local Caddyfile, accepts a small audited directive subset for the private Search site, and rejects ambiguous, additional, or permissive routing. In particular, active import directives block source admission until their expansions have been resolved and reviewed; case-insensitive hostname aliases and any second Development gateway target also block. It does not print the Caddyfile or secret values, and produces one bounded JSON result.

```
python3 scripts/search_development_ingress_guard.py \
  --caddyfile deploy/vps/Caddyfile.search \
  --expected-upstream goreecloud-search-gateway:8080
python3 -m unittest discover -s tests/goreecloud \
  -p 'test_search_release_acl_guard.py' -v
```

pass_static_only is limited to the inspected file bytes and specified upstream. A refusal returns exit status 2 and blocked_do_not_cutover. This guard also backs the unique_netbird_only_host check of the established scripts/free_upgrade_preflight.py release review for its legacy and working gateway phases. The surrounding preflight retains its independent exact-image, snapshot, owner, network, volume and provider-profile checks.

The optional --require-public-host mode also rejects configurations without an exact separate search.goreecloud.com block. A narrowly validated static 503 maintenance response with usable TLS, or a distinctly public/prod-named backend, may pass **structural** admission. Redirects, catchalls, private Search upstreams, aliases and a false-success 200 placeholder cannot. This opt-in check does not provision DNS, issue certificates, qualify a public image, or authorize a cutover. The default check remains private-only.

Adversarial fixtures deliberately reject a bypassing site-level proxy, public-client fallback proxy, malformed 403, altered NetBird mask, duplicate handler, unexpected Caddy route/log directives, duplicate host alias, incomplete braces, unreviewed includes, case-variant vhosts and a public Search vhost accidentally targeting the private gateway. A separately routed public Search site with a literal independent upstream is not automatically prohibited; its independent qualification remains outside this Development-only guard.

Gates this check cannot satisfy

Before any public service or Dev promotion, retain the separate requirements:

1. Validate the **actual composed** Caddyfile using the exact running Caddy binary and resolve any imports, snippets, matchers, DNS and proxy aliases.
2. Verify that an authorized NetBird client succeeds and a truly non-NetBird client gets 403, with TLS verified and no direct Search container port.
3. Confirm privacy, multiuser rate limiting, abuse/SSRF defenses, provider availability and provider-contract rights for each data source. The Google/Bing/Brave native-fusion vision does not itself grant licensed access or redistribution, and an offline adapter does not prove live SERP coverage.
4. Prove precise deployed image/source provenance, secret handling, runtime isolation, recoverable snapshots, real rollback, representative UI/device acceptance, observability and sustained reliability.
5. Complete the governed Seal/Anchor acceptance and separately authorize public exposure; do not infer public readiness from CI or a green static gate.

Verified read-only network findings

From the connected NetBird laptop and primary VPS, with no configuration changes, the public search.goreecloud.com A record resolved to 135.148.45.22, with no public AAAA returned. Plain HTTP returned a 308 redirect to HTTPS; HTTPS reached the public VPS but failed its TLS handshake. The running Caddy container used the mounted /srv/docker/caddy/Caddyfile, which had **no search.goreecloud.com site block**. This is a concrete public-ingress configuration gap, not evidence of a qualified public backend.

The NetBird-only search-dev.goreecloud.com/readyz returned HTTP 200 with valid TLS from the authorized laptop. The same hostname pinned to the VPS's public IPv4 returned HTTP 403 with valid TLS. No public IPv6 endpoint was observed; independent IPv6 denial remains **unverified**, not passed. The source-only acceptance probe and static Caddy check cannot replace exact running-config adaptation, live TLS issuance, public backend qualification, dual-stack route testing where applicable, rollback or production acceptance.

Current release hold: Keep Development private. Before any live public host mutation, prepare and validate a separately named Caddy site, initially serving a truthful HTTP 503 if no qualified public backend exists; preserve a validated backup/rollback and recheck every existing host after a staged reload. No DNS, NetBird policy, Caddy instance, running container, provider account, certificate or user traffic was modified by this source milestone.